

Data Privacy Guideline

Nova Insurance Group | Guideline NIG-GDL-DPR-002

1. Introduction

Nova Insurance Group is committed to protecting the personal data of its customers, employees and business partners. As a regulated insurance undertaking operating across the European Economic Area (EEA), the Company is subject to the General Data Protection Regulation (EU) 2016/679 (GDPR), the German Federal Data Protection Act (BDSG) and applicable national implementing legislation.

This guideline translates legal obligations into practical, day-to-day guidance for all staff. Compliance with this guideline is mandatory. Questions should be directed to the Data Protection Officer (DPO) at dpo@nova-insurance.eu.

2. Key GDPR Principles

Lawfulness, Fairness & Transparency

Personal data may only be processed where a lawful basis exists (Art. 6 GDPR). Data subjects must be informed via the privacy notice.

Purpose Limitation

Data collected for a specific purpose may not be used for an incompatible purpose without a fresh legal basis or explicit consent.

Data Minimisation

Only the minimum amount of personal data necessary for the stated purpose should be collected and retained.

Accuracy

Personal data must be kept accurate and up to date. Inaccurate data must be corrected or erased without undue delay.

Storage Limitation

Personal data must not be retained longer than necessary. Refer to the Retention Schedule on the intranet for category-specific limits.

Integrity & Confidentiality

Data must be protected against unauthorised access, accidental loss, destruction or damage through appropriate technical and organisational measures.

Accountability

The Company must be able to demonstrate compliance with all of the above principles (Art. 5(2) GDPR). Records of processing activities (RoPA) must be maintained.

3. Lawful Bases for Processing

Lawful Basis	When it Applies at Nova Insurance Group
Contract (Art. 6(1)(b))	Processing policyholder or claimant data to fulfil or enter an insurance contract.
Legal Obligation (Art. 6(1)(c))	AML/KYC checks, regulatory reporting, tax obligations.
Legitimate Interests (Art. 6(1)(f))	Fraud prevention, network security, internal analytics (subject to balancing test).
Consent (Art. 6(1)(a))	Marketing emails, optional analytics cookies. Must be freely given, specific and withdrawable.
Vital Interests (Art. 6(1)(d))	Emergency medical assistance in claims contexts only.

4. Special Category Data

Special category data (Art. 9 GDPR) — including health, biometric, genetic, racial/ethnic origin, political opinions and sexual orientation data — requires an additional condition under Art. 9(2) in addition to a standard Art. 6 lawful basis. At Nova Insurance Group, the primary conditions are:

- Explicit consent of the data subject (e.g., medical questionnaires for life insurance).
- Processing necessary for insurance purposes under Art. 9(2)(b) and national derogations (§ 22 BDSG).
- Establishment, exercise or defence of legal claims (e.g., litigation support).

Access to special category data is restricted to authorised personnel only. Any new use case involving special category data requires DPO and Legal sign-off before processing begins.

5. Data Subject Rights

Employees who receive a data subject request (DSR) from a customer or employee must forward it to the DPO team within one business day. Do not attempt to handle DSRs independently. The Company has a 30-day statutory response window (extendable by 2 months for complex requests). Recognised DSRs include:

- Right of access (Art. 15) — subject access requests.
- Right to rectification (Art. 16) — correction of inaccurate data.
- Right to erasure (Art. 17) — 'right to be forgotten' (subject to legal holds).
- Right to restriction of processing (Art. 18).
- Right to data portability (Art. 20) — for contract/consent-based processing.
- Right to object (Art. 21) — particularly to direct marketing and profiling.

6. International Transfers

Transferring personal data outside the EEA requires one of the following safeguards:

- Adequacy decision by the European Commission (e.g., transfers to the UK, Switzerland).
- Standard Contractual Clauses (SCCs) approved under the EU GDPR framework.

- Binding Corporate Rules (BCRs) for intra-group transfers.

No personal data may be sent to a third country or international organisation without prior written approval from the DPO. This includes cloud services, outsourcing partners and any AI tool where data is processed outside the EEA.

7. Data Breach Notification

A personal data breach must be reported internally to the DPO within 2 hours of discovery via the Incident Reporting Portal or by calling the Security Hotline (+49 711 900 2911). The DPO will assess whether notification to the supervisory authority (BfDI or relevant Landesbehörde) is required within 72 hours (Art. 33 GDPR) and whether affected individuals must be notified (Art. 34 GDPR).

Do not attempt to investigate or contain a breach without involving the DPO and IT Security team. Do not communicate about a breach externally without authorisation.

8. Privacy by Design and Default

All new projects, products, systems and processes that involve personal data must go through a Data Protection Impact Assessment (DPIA) where required by Art. 35 GDPR. A DPIA is mandatory when:

- Systematic and extensive profiling is used to make decisions about individuals.
- Large-scale processing of special category data is involved.
- Systematic monitoring of publicly accessible areas is undertaken.
- New technologies are deployed (including AI systems) that may create risks for data subjects.

9. Contact and Resources

Resource	Contact / Location
Data Protection Officer	dpo@nova-insurance.eu Ext. 2911
DPIA Template	Intranet > Compliance > Privacy > Templates
Retention Schedule	Intranet > Compliance > Privacy > Retention
Incident Portal	https://intranet.nova-insurance.eu/security/incident
Privacy Training	Intranet > HR > Learning > Privacy 2025